

UC: ESSI/NS

TP1 Report – Simplified Risk Analysis /Análise de Risco simplificada

Grupo constituído por (Nº / Nome): pg61434/ Luis Baptista, pg59972/ Bernardo Salgado

1. Tabela de Análise

Tabela 1 - Tabela de Análise

Threats / Ameaças	Attacks / Ataques	Vulnerabilities / Vulnerabilidades	Valor do Risco / Risk Value	Propriedades (CIA)
1.Compromisso da rede SCADA via rede Corporate	Movimento lateral: um atacante compromete um PC na rede do escritório (Corporate) e consegue "saltar" para o sistema SCADA porque as redes estão ligadas.	- Falta de separação (segmentação) clara entre a rede IT e a rede OT. - Ligação direta sem uma DMZ ou firewall adequada. - Controlos de acesso fracos.	R = Alto * Elevada = Crítico Valor (V): Alto – A rede SCADA controla processos industriais perigosos e críticos. Probabilidade (P): Elevada – É muito	Disponibilidade e Integridade Se o ataque acontecer, pode haver paragem operacional (Disponibilidade) e perda de controlo dos processos (Integridade).

			comum as redes estarem mal separadas e os ataques de phishing na rede de escritório são frequentes.	
2. Malware via Manutenção	Infeção por vírus ou ransomware através de pens USB infetadas ou acessos remotos (VPN) pouco seguros usados para manutenção.	- Passwords fracas nos acessos remotos. - Ninguém verifica se as pens USB têm vírus. - Sistemas operativos velhos e sem updates (patching) nos PLCs. - Falta de bloqueio de aplicações desconhecidas.	R = Muito Alto * Média-Alta = Crítico Valor (V): Muito Alto – Se o firmware dos PLCs for corrompido, perde-se o controlo remoto e obriga a ir ao local arranjar manualmente. Probabilidade (P): Média-Alta – Com mais acesso remoto pós-COVID e a dificuldade	Integridade e Disponibilidade Afeta a integridade do firmware e impede o controlo remoto (Disponibilidade).

			em parar as máquinas para atualizar, o risco aumenta.	
3. Ameaça Interna (Insider Threat)	Um funcionário ou subcontratado com acessos legítimos decide sabotar o sistema ou roubar dados.	- As pessoas têm mais acessos do que precisam (privilégios excessivos). - Falta de monitorização do que os utilizadores fazem. - Logs insuficientes para detetar problemas.	R = Alto * Média = Alto Valor (V): Alto – Alguém que conhece o sistema por dentro pode causar muitos estragos ou roubar segredos. Probabilidade (P): Média – Acontece menos que ataques externos, mas é perigoso, especialmente com empresas externas contratadas.	Confidencialidade, Integridade e Disponibilidade Pode haver roubo de dados (Confidencialidade), mudança de parâmetros (Integridade) ou sabotagem (Disponibilidade).

2. Discussão do Maior Risco

Critical resource / Recurso crítico: SCADA Server / HMI (Human-Machine Interface)

Justificação: Na nossa análise, identificámos o Servidor SCADA (e a HMI) como o componente de maior risco nesta infraestrutura. Isto deve-se a três razões principais:

1. É o centro de tudo: O Servidor SCADA controla todos os dispositivos no terreno (PLCs e RTUs). Se este servidor for comprometido, perdemos a visibilidade e o controlo sobre todo o processo industrial.
2. Localização na rede: Como se pode ver na *Figura 1*, este sistema está numa posição de "ponte" entre a rede do escritório (Corporate) e os dispositivos industriais. Isso torna-o o alvo perfeito para quem quer passar de uma rede para a outra.

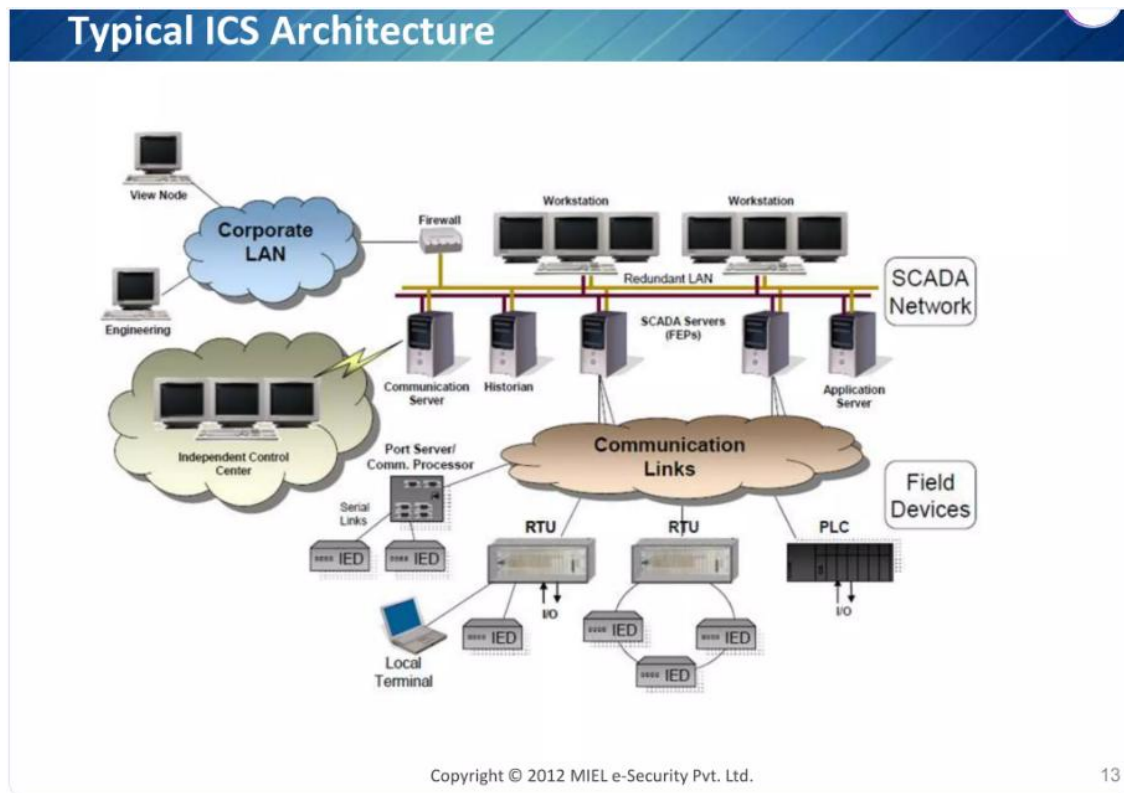


Figura 1 - Arquitetura ICS, consultado de Critical Infrastructure Security by Subodh Belgi

3. Impacto na Disponibilidade: Se o SCADA falhar, a fábrica tem de passar a operar manualmente. Isto aumenta muito o tempo de recuperação, como se viu no ataque à rede elétrica da Ucrânia, onde demoraram horas a repor a luz.

Risco Agregado: R = Muito Alto * Elevada = Crítico

3. Controlo de Mitigação

Security control / Controlo de segurança: Criação de uma DMZ com Data Diode e Firewall Industrial

Justificação: Para resolver o problema da falta de separação entre as redes, propomos a criação de uma Zona Desmilitarizada (DMZ) entre a rede Corporate (IT) e a rede SCADA (OT). As medidas específicas incluem:

- Data Diode: Usar um gateway que fisicamente só deixa os dados saírem da fábrica para o escritório (para logs e relatórios), mas impede que entrem ataques ou comandos vindos da rede Corporate.
- Firewall Industrial: Colocar uma firewall que entenda os protocolos industriais (como Modbus ou DNP3). Ao contrário das firewalls normais, esta consegue inspecionar o conteúdo dos pacotes para detetar comandos estranhos.
- Jump Server: Para os administradores entrarem na rede, não devem ligar-se diretamente. Devem usar um "Bastion host" na DMZ, com autenticação forte (MFA) e gravação de sessões.

Por que escolhemos isto? Esta solução resolve diretamente as ameaças que identificámos: bloqueia o movimento lateral (Ameaça 1), controla melhor os acessos remotos contra malware (Ameaça 2) e ajuda a vigiar o que os utilizadores internos fazem (Ameaça 3). Segue também as boas práticas de "defesa em profundidade" da ENISA.

Referências

- ENISA. (2017). Communication network dependencies for ICS/SCADA Systems. Consultado em <https://www.enisa.europa.eu/publications/ics-scada-dependencies>
- ENISA. (2024). Foresight Cybersecurity Threats for 2030 Update. Consultado em <https://www.enisa.europa.eu/publications/foresight-cybersecurity-threats-for-2030-update-2024>
- Infosec Institute. (2021). ICS/SCADA Threats and Threat Actors. <https://www.infosecinstitute.com/resources/scada-ics-security/ics-scada-threats-and-threat-actors/>

